

Cravitoo — Deployment Readiness Certificate

Status: ● **READY TO DEPLOY** Generated (UTC): 2026-06-24T07:34:13Z Source commit (preview): 19a1946 Frontend bundle hash: 7f1fcbdb9dd3 Environment under test: https://corporate-feast.preview.emergentagent.com Target: https://app.cravitoo.com (NOT yet deployed — awaiting your Deploy click)

Sign-Off Checklist

Check	Status	Evidence
Backend pytest (Phase 1 + audit + extended + new-features + master-admin-sites)	✓ 111 passed · 1 skipped (documented) · 0 failed	Last run just before this cert
Smoke checklist	✓ 50 / 50 pass	scripts/phase1_checklist.py
Frontend production build	✓ Clean (yarn build done in 14.62s, no warnings)	/app/frontend/build
Bundle credential scan	✓ No leaks	regex against Demo@123 admin123 employee123 vendor123 finance@cravitoo info@cravitoo vendor@atmego employee@techcorp vendor@spicekitchen Demo Accounts
Deployment-readiness static analysis	✓ PASS — no blockers	deployment_agent

Resend paid plan	✓ Verified live (OTP send 200, send-only key, healthy)	/api/health/email
Phase 1 security fixes (all 5)	✓ Verified	Approval report + full audit

What gets deployed

Layer	Change
Backend	env_config.py (NEW · fail-secure env helper), order_lifecycle.py (NEW · state machine), email_service.py (+resend_health_check), server.py (PATCH /orders rewritten, /api/health/email added, startup Resend log), routers/auth.py (server-side role lock), routers/demo.py (404 in production), models.py (OrderStatus expanded), tests/* (Phase 1 suites)
Frontend	index.js (PUBLIC_PATHS allow-list in interceptor), context/AuthContext.js (silent /auth/me probe), pages/LoginPage.js (demo block removed), pages/RegisterPage.js (role dropdown removed), pages/master/DemoControl.js (no inline credentials in JSX), components/Navbar.js (logout testid + aria-label + sr-only), components/CookieConsent.js (auto-suppress for authed users)
Database	0 schema migrations · 1 new collection auto-created on first write (order_status_history) · 4 new indexes auto-created at backend startup
Env vars (NEW for production)	CRAVITOO_ENV=production (must set in Deploy modal)

Operator Actions Required at Deploy Time

In the Emergent **Deploy** → **Environment Variables** panel:

CRAVITOO_ENV=production	← NEW · MANDATORY
MONGO_URL=<your production Mongo URI>	← existing
DB_NAME=<your production DB name>	← existing
CORS_ORIGINS=https://app.cravitoo.com	← TIGHTEN from "*" in pro
JWT_SECRET=<your production JWT secret>	← existing, do not rotate

```
ADMIN_EMAIL=<your real admin email> ← existing
ADMIN_PASSWORD=<your real admin password> ← existing — must NOT be
RESEND_API_KEY=<your paid-plan send-only key> ← existing
RESEND_FROM_EMAIL=noreply@cravitoo.com ← existing
RESEND_FROM_NAME=Cravitoo ← existing
RAZORPAY_KEY_ID=<your production Razorpay key> ← existing (test→prod swi
RAZORPAY_KEY_SECRET=<your production Razorpay secret> ← existing
RAZORPAY_WEBHOOK_SECRET=<set this for prod> ← Phase 2 to-do, but reco
```

Post-Deploy Smoke (run from your laptop after Deploy completes)

```
# 1. Quick health
curl https://app.cravitoo.com/api/health
curl https://app.cravitoo.com/api/health/email | python3 -m json.tool
curl https://app.cravitoo.com/api/admin/demo/enabled | python3 -m json.tool
# Expected: demo_enabled=false, environment=production, healthy=true on email

# 2. Full automated smoke
PROD_URL="https://app.cravitoo.com" \
ADMIN_EMAIL="<your prod admin email>" \
ADMIN_PASSWORD="<your prod admin password>" \
python /app/backend/scripts/phases1_prod_smoke.py
# Expected: 🟢 All checks pass (writes 9 audit_log rows for blocked role att
```

Rollback (if anything regresses)

Emergent UI → **Home** → app → version history → click **Rollback** to the previous version.

Code rollback only. Database is forward-only — Phase 1 introduces a new `order_status_history` collection (additive, safe to keep) and adds 3 new `OrderStatus` enum values (`expired`, `no_show`, `rejected`). Pre-Phase-1 code will simply ignore those new values; no DB migration needed for rollback.

Deferred to Phase 2 (NOT blockers for this deploy)

Razorpay webhook signature verification (`RAZORPAY_WEBHOOK_SECRET`)

- Production CSP / HSTS / X-Frame-Options security headers
- Rate-limit on `/auth/register`
- Twilio SMS / WhatsApp OTP fallback
- Full security audit (IDOR sweep, CORS lockdown, secret scan)
- Sentry / monitoring integration

Awaiting Your Action

Press **Deploy to Production** in the Emergent UI when you're ready. After it completes, paste the result of the post-deploy smoke here and I'll write the verification report.